.sova: Portable, Evidence-Bounded Reproduction of AI-Agent Security Findings

TRUSCOR Private Limited - gautam@truscor.org

Gautam R. Patil

2026-08-20

Abstract

AI-agent security findings are commonly exchanged as prose reports, screenshots, logs, or replay scripts. These artifacts can preserve useful observations while remaining ambiguous about the behavior claimed, the execution context that must remain equivalent, and whether redaction or conversion removed evidence needed to support the claim. We introduce .sova, an inert-by-default behavior capsule, and .sova-trace, its canonical observable evidence stream. The proposed decision procedure composes a typed outcome contract, an execution-context equivalence envelope, claim-conditioned evidence requirements, integrity and trust checks, multi-valued reproduction states, and recomputable repeated-trial summaries. On two frozen same-team corpora, the complete mechanism matched all 144 semantic-reproduction labels and all 120 evidence-fidelity labels; simple structural, integrity-only, and profile-only baselines could not represent the same decision space. A separate frozen public-contract study matched all expected decisions for 12 contracts and 96 candidate traces while accepting zero incomplete traces as reproduced. On eleven retrospective cross-model pairs derived from 22 AgentRewardBench WebArena trajectories, the mechanism returned two equivalent, five divergent, and four inconclusive decisions. A calibrated semantic-text baseline matched all seven conclusive labels but necessarily forced the four inconclusive cases into a binary outcome. Interoperability studies exercised official Inspect fixtures, OTLP protobuf, an OpenTelemetry Collector, STIX 2.1, cross-language verification, and signed traces up to 50,000 events with explicit loss accounting. These results establish an executable and falsifiable architecture, not independent cross-runtime superiority. The confirmatory gate remains independently authored claims, blinded labels, independently operated runtimes, and external security and privacy review.

PUBLIC PREPRINT - VERSION 1.0
This manuscript has not been peer reviewed.

Affiliation: TRUSCOR Private Limited
Contact: gautam@truscor.org
License: CC BY 4.0 - (c) 2026 Gautam R. Patil
arXiv classification: cs.CR (cross-list candidates: cs.AI, cs.SE)

1. Introduction

A security finding is useful only when another party can determine what was observed, under which conditions, and whether the retained evidence supports the stated conclusion. This is difficult for AI agents because outcomes can depend on stochastic model behavior, tool and protocol versions, permissions, memory, retrieval, browser state, and external effects. Exact byte replay is often impossible, while unconstrained semantic similarity can declare two executions equivalent despite materially different context or missing evidence.

Existing evaluation logs, provenance records, signed attestations, replay systems, trajectory matchers, and semantic metrics address important portions of this problem. They do not by themselves answer a narrower compound question: did a declared observable security behavior recur in a sufficiently equivalent context, and does the supplied evidence still support that conclusion after capture, conversion, redaction, or export?

We investigate whether that decision can be made portable and independently recomputable. The proposed artifact separates three operations:

1. trace playback, which renders an inert recorded timeline;

2. controlled re-execution, which performs a fresh authorized run and emits new evidence; and
3. semantic reproduction, which compares the fresh evidence with a declared outcome, context, and evidence contract.

The paper makes three bounded contributions:

1. a portable .sova capsule that binds a declared behavior, context-equivalence envelope, evidence requirements, trials, and limitations;
2. a claim-conditioned .sova-trace fidelity decision that separates transport integrity from evidentiary sufficiency and preserves unsupported or inconclusive states; and
3. an executable composition rule and evaluation showing why byte equality, terminal status, structural trajectory matching, semantic similarity, integrity validity, or a capture-profile name alone answer narrower questions.

We do not claim invention of archives, tracing, signatures, replay, provenance, semantic metrics, statistical intervals, or selective disclosure. We also do not claim access to hidden model reasoning, recorder honesty, trace completeness, non-repudiation, or field superiority. The present evidence is bounded and largely same-team; the independent confirmatory study is specified but not represented as completed.

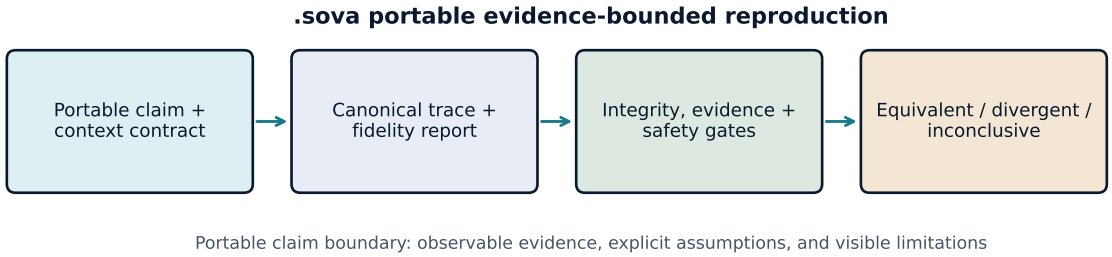


Figure 1: The .sova decision boundary composes a portable claim and context contract with verified observable evidence. Execution and evidence production remain outside the decision claim.

2. Related work and claim boundary

ReproEvalCard identifies reproducibility-critical material for LLM evaluation pipelines (Pattnayak and Bhatia 2026). agrepl records and deterministically replays external interactions (Mudasiru 2026). WebGraphEval represents web-agent trajectories as canonical graphs (Qian et al. 2025), while ContractEval and Phoenix illustrate explicit behavioral-contract evaluation (Lim et al. 2026; Wang and Huang 2026). PoC-Adapt uses structured semantic oracles for vulnerability reproduction (Duy et al. 2026).

The closest integrity-focused overlap is AEGIS, a portable, offline-verifiable evidence bundle that separates post-capture integrity from capture completeness and accountability sufficiency (Li 2026). A trace-based assurance framework for agentic orchestration combines message-action traces, step and trace contracts, deterministic replay, fault injection, and governance decisions (Paduraru et al. 2026). A contemporaneous survey treats typed execution provenance and evidence-support relations as foundations for agent accountability and identifies unified trace schemas, claim-level provenance, benchmarks, and privacy-aware audit infrastructure as open problems (Wang et al. 2026). These works materially narrow any novelty claim: signed portable traces, execution contracts, and evidence provenance are not new by themselves.

OpenTelemetry provides broad trace and event semantics (OpenTelemetry Authors 2026b, 2026a). Inspect preserves rich AI evaluation logs (UK AI Security Institute 2026), and OpenInference defines AI-observability conventions (Arize AI 2026). W3C PROV formalizes provenance constraints and access (World Wide Web Consortium 2013b, 2013a). in-toto, DSSE, Sigstore, and RFC 8785 provide established supply-chain, signing, bundle, and canonicalization mechanisms (Torres-Arias et al. 2019; Secure Systems Lab 2023; Sigstore Authors 2026; Rundgren et al. 2020). STIX 2.1 provides an established incident interchange model (OASIS Open 2021).

The candidate delta is not a new member of any one of those classes. It is the ordered composition of observable outcome semantics, explicit context equivalence, claim-specific evidence sufficiency, integrity

and trust decisions, multi-valued reproduction outcomes, and retained uncertainty inside one inert-by-default AI-behavior artifact. In particular, an integrity-valid sequence may still be insufficient for a claim, and an outcome-matching run may still be incompatible, unsafe, evidence-invalid, or inconclusive. The literature search did find substantial neighboring work; it did not establish that no other system implements the same composition. A close system that does would narrow or defeat the contribution, so the paper keeps the mechanism, comparisons, and search boundary inspectable rather than claiming categorical priority.

3. Artifact and threat model

3.1 .sova capsule

A .sova capsule is versioned and inert by default. It packages or references:

- the security claim and typed observable outcome predicates;
- the scenario, trigger, model, agent, tools, permissions, and dependencies;
- a context-equivalence envelope;
- one or more .sova-trace streams and content-addressed artifacts;
- evidence requirements, capture profiles, redaction and conversion reports;
- trials, findings, limitations, provenance, integrity, authorship, and citation records.

Opening a capsule does not authorize execution. A fresh run requires an explicitly admitted executor and a separate authorization decision. This paper evaluates the portable decision after evidence has been produced; it does not claim that ordinary local process restriction is a security sandbox.

3.2 .sova-trace

A .sova-trace is a canonical stream of observable events and evidence references. Events retain identity, kind, actor, local sequence, timestamps and clock description, causal parents, observation role, payload or artifact reference, redaction state, and integrity linkage where available. The stream records what an admitted observer reported. It does not reveal private model thoughts or prove that an uninstrumented event did not occur.

The completeness vocabulary separates:

1. package continuity;
2. local event-chain continuity;
3. recorder-reported dropped data;
4. sensor coverage;
5. source completeness; and
6. semantic sufficiency for a named claim.

No signature or hash chain collapses these six meanings into a universal “valid trace” Boolean.

3.3 Adversary and residual trust

The evaluated threat model includes malformed archives, traversal, duplicate members, excessive compression, event insertion, deletion, reordering, substitution, duplicate identifiers, forward causal parents, invalid signatures, signer-policy mismatch, malformed redaction placeholders, capture-profile loss, conversion loss, and truncated tails.

Residual threats include a dishonest or compromised recorder, an uninstrumented source, colluding signer and recorder, incorrectly authored claim requirements, unverifiable external timestamps, schema-valid malicious extensions, and privacy inference from retained structure. The decision can propagate known gaps; it cannot discover every unknown omission.

4. Evidence-bounded reproduction

4.1 Observable outcome contract

A claim declares required and optional predicates over observable event families. The current implementation supports existence, absence, equality, containment, minimum count, and ordering. Each predicate identifies the event family, value path, relation, and evidence events used.

A missing required event family evaluates to unknown, not pass or fail. Optional human, model, or rule adjudication records are typed and retain identity, version, inputs, configuration, blinding, confidence, and private- rationale digests. They never silently override deterministic evidence.

4.2 Context-equivalence envelope

Each context dimension declares one comparison mode:

- exact: values must match;
- one-of: the candidate must belong to an allowed set;
- tolerance: numeric deviation is bounded;
- record: divergence is recorded but does not block comparison; or
- ignore: the dimension is explicitly non-material.

Missing required context produces an unknown comparison. The envelope prevents a receiver from silently treating an absent model, tool, protocol, dependency, permission, or environment version as equivalent.

4.3 Claim-conditioned fidelity

For each claim, the producer declares required event kinds and counts, payload paths, content requirements, tolerated redaction, causal-parent requirements, observation roles, and integrity and signer-trust assumptions. Every requirement evaluates to present, redacted, omitted, missing, invalid, or unverified.

The evidence state is:

- supported when every mandatory requirement is present and accepted;
- weakened when only explicitly tolerated or optional evidence degrades; or
- inconclusive when mandatory evidence is absent, invalid, irreversibly redacted, or outside the supplied trust policy.

The safety invariant is monotonic: removing, invalidating, or making required evidence unavailable cannot increase claim support. This invariant is evaluated over claim support, not over the truth of the external world.

4.4 Composed decision

The comparison applies gates in a fixed order:

1. malformed or integrity-invalid evidence yields evidence-invalid;
2. prohibited or unauthorized execution yields unsafe;
3. materially incompatible context yields incompatible;
4. missing context or mandatory evidence yields inconclusive;
5. a failed required outcome predicate yields divergent; and
6. only sufficiently evidenced matching predicates yield equivalent.

This order matters. Provider success, terminal completion, a valid package digest, or high semantic similarity cannot override an unsafe run, incompatible context, or mandatory evidence gap.

4.5 Repeated trials

Each trial retains its state, environment stratum, evaluator identity, and evidence digest. Summaries report every state, the equivalent rate among conclusive trials, Wilson and exact binomial intervals, and a partial- identification interval treating inconclusive trials as unresolved rather than silently deleting them. Correlated trials must be grouped; a field study should use a hierarchical or mixed model where model, item, environment, and judge variation warrant it (Keller, Steed, et al. 2026; Keller, Kwegyir-Aggrey, et al. 2026).

5. Implementation and interoperability

The reference implementation uses deterministic canonical events, content-addressed blobs, segmented streams, explicit capture profiles, typed redaction placeholders, DSSE-compatible manifests, required-key verification, and dependency-closed selective disclosure. Independent Python and dependency-free Node.js verifiers recompute package and event-chain digests and check required-key Ed25519 signatures. They do not establish external timestamp or transparency state.

Adapters translate bounded subsets of Inspect, OpenInference, OTLP, and STIX records. Every adapter emits a fidelity report instead of implying lossless equivalence. Unsupported layouts or missing semantics are typed refusals or declared losses. The implementation also separates inert playback from fresh execution and records executor observations independently from provider status.

A disclosure prototype starts from claim evidence and computes causal ancestor closure. Revealed events include bytes and nonces; unrelated events retain domain-separated salted commitments. The authenticated root is external to the prototype. This is an engineering use of established commitments, not a new cryptographic primitive or zero-knowledge system.

6. Evaluation

The evaluation asks:

- RQ1: Does the composed mechanism distinguish the declared reproduction and fidelity states on frozen constructed cases?
- RQ2: Which errors appear when context, evidence, or integrity components are removed?
- RQ3: Can the same decision be exercised over public contracts, external fixtures, retrospective real-model trajectories, and standard interchange paths without concealing loss?
- RQ4: Which conclusions remain unsupported by the current evidence?

All headline constructed labels and transformations are same-team. External fixtures and independent libraries reduce implementation coupling but do not create independent scientific labels.

6.1 Frozen constructed corpora

The semantic-reproduction corpus contains 144 pairs balanced across equivalent, divergent, inconclusive, incompatible, unsafe, and evidence-invalid states. The fidelity corpus contains 120 claim/trace combinations covering complete evidence, required-content redaction, omitted event families, invalid integrity, missing causal parents, and unverified signer policy.

Semantic-reproduction method	Macro-F1
Complete composed mechanism	1.000
Exact canonical trace	0.111
Exact final payload	0.000
Terminal completion status	0.048
Untyped event-kind equality	0.048
Remove context envelope	0.778
Remove evidence-validity gate	0.778
Collapse inconclusive into failure	0.778

Evidence-fidelity method	Accuracy
Claim-conditioned fidelity	1.000
Integrity valid alone	0.333
Capture-profile name alone	0.167
Full-share assumption	0.167
Remove causal-parent requirements	0.833
Remove full-content requirements	0.833

The complete mechanisms made zero false-equivalence, false-divergence, or false-support decisions under the construction rules. Those perfect values are optimistic: the same team designed the transformations and evaluators. The results show executable specification consistency and falsify the listed ablations; they do not estimate field performance.

6.2 End-to-end public-contract study

A separate frozen protocol defined 12 observable contracts. Each contract was evaluated against eight deterministic candidate traces: four equivalent- runtime variations, two material-outcome variations, and

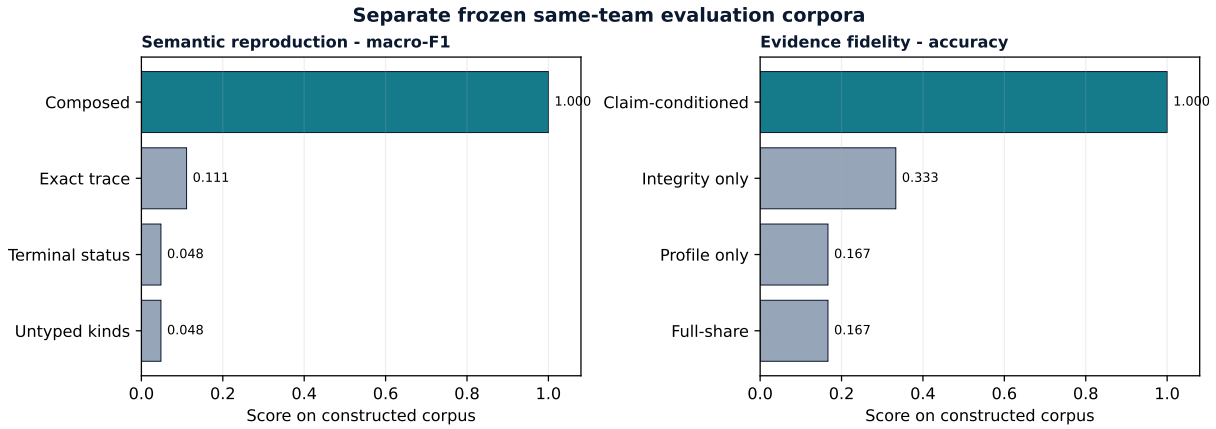


Figure 2: Separate constructed-corpus results for semantic reproduction and evidence fidelity. The panels use different metrics and must not be compared as one shared score.

two traces missing mandatory evidence. The expected vector was four reproduced, two not reproduced, and two inconclusive.

All 96 decisions matched the frozen expectations. No incomplete trace was accepted as reproduced, and no candidate was an exact transport-byte match. Every aggregate remained inconclusive because it retained two mandatory- evidence gaps. This intentionally adverse headline demonstrates that the implementation does not manufacture a success rate by dropping unresolved trials. The fixtures remain same-team and rule-derived.

6.3 External fixtures and retrospective trajectories

At the pinned Inspect commit, 13 official JSON logs contained transcript, legacy-flat, no-event-stream, and no-sample layouts. Adapter 0.2 accepted 5/13 and refused eight because it assumed transcript events. That failure was retained. Adapter 0.3 added explicit layout detection, accepted the unchanged 13/13 corpus, converted 14 samples and 200 source events into 280 verified SOVA events, and declared every conversion lossy.

The official AgentRewardBench demo supplied 22 cleaned WebArena trajectories from two real-model agent families over eleven shared tasks (Lu et al. 2025). The retained conversion excluded goals, raw reasoning, arguments, screenshots, accessibility trees, URLs, chat messages, and annotator identities. Eleven cross-model pairs produced:

Decision	Count
Equivalent	2
Divergent	5
Inconclusive	4

The equivalent rate among seven conclusive pairs was 2/7, with a two-sided Wilson interval of 0.0822-0.6411. Treating the four inconclusive pairs as unresolved yielded a partial-identification interval of 0.1818-0.5455 over all eleven pairs.

A deterministic two-pass action-graph baseline matched 5/7 conclusive labels and missed both equivalent pairs. A Model2Vec semantic-text baseline calibrated on the STS Benchmark test split achieved 0.8216 accuracy and 0.1267 Brier score on that calibration task (Cer et al. 2017). With a disclosed post-result threshold it matched 7/7 conclusive trajectory labels but had no representation for the four inconclusive decisions and forced them to divergent. This is useful negative evidence: similarity may recognize outcome equivalence while remaining silent about authorization, context, evidence sufficiency, and abstention.

The retrospective cohort is small, selectively exposed, and not a controlled re-execution study. Its SOVA interpretation is same-team. It cannot support a population, state-of-the-art, or independent-validity claim.

6.4 Integrity, privacy, interchange, and scale

Independent securesystemslib verification accepted the intended DSSE envelope and rejected payload, signature, key, key-ID, and non-canonical-substitution mutations. RFC 8785 cross-library tests agreed on all 65 values in SOVA's intentionally shared domain; SOVA refused an out-of-domain binary float rather than claiming full JCS number support.

The privacy study confirmed:

- dictionary recovery for unkeyed low-entropy digests;
- recovery after a keyed commitment key was treated as compromised;
- within-context equality leakage and tested cross-context separation;
- exact plaintext-length leakage from unpadded encryption;
- residual bucket, path, presence, and structural leakage after padding; and
- a deliberate detector false negative for a generic sensitive string.

The results motivated authenticated power-of-two padding and a default of omission for public secrets. They do not constitute a cryptographic or privacy audit.

Official OTLP protobuf preserved the declared trace, span, parent, link, name, time, attribute, and event-count subset while explicitly losing SOVA authorization, redaction, monotonic ordering, and event-chain semantics. A checksum-verified OpenTelemetry Collector v0.157.0 received eight local OTLP/HTTP spans and emitted eight file records with required projection attributes. A STIX 2.1 projection passed the official parser and retained source digest references while declaring loss of the raw stream, full causal graph, authorization, redaction history, replay procedure, environment requirements, and trust policy.

Signed synthetic traces at 1,000, 10,000, and 50,000 events passed required-key verification, indexed queries, 100-event minimized disclosure, and independent Python/Node digest agreement. The 50,000-event run used 50 segments, captured 325.6 events/s on one Windows host, produced a 6,183,508-byte package, and reached 54,973,724 traced peak bytes. These are diagnostic one-host values, not production performance claims.

6.5 Statistical correction and retained negative results

The preregistered uncertainty study initially required nominal 95% Wilson coverage. Aggregate coverage passed, but the stricter worst-cell interpretation failed at 0.914. The original failure was retained. A disclosed amendment added a two-sided Clopper-Pearson interval, whose minimum analytic coverage over the same grid was 0.956. The exact interval is established prior art and is not a contribution.

Other retained negative results include the Inspect 0.2 layout failure, component ablations that created false support, graph similarity missing both retrospective equivalent pairs, semantic similarity forcing every unresolved pair into a binary class, and aggregate reproduction remaining inconclusive despite four matching trials per contract.

7. Security and privacy implications

The architecture helps a reviewer distinguish four questions:

1. Are the supplied bytes internally intact?
2. Does the accepted signer or observer policy apply?
3. Is the required evidence present and usable for this claim?
4. Did the declared observable behavior recur in an acceptable context?

An affirmative answer to an earlier question does not imply an affirmative answer to a later one. This blocks several forms of evidence laundering, such as treating provider success as observed effect, a valid signature as recorder truth, a named capture profile as actual coverage, or semantic similarity as proof of compatible context.

The same detail that improves reproduction can increase privacy and dual-use risk. Public capsules should minimize content, omit secrets, disclose only claim dependencies, record residual leakage, and require fresh authorization before any effectful re-execution. Unsafe cases remain refusals rather than failed experiments.

8. Threats to validity

Construct validity

The mechanism evaluates author-declared contracts. Incorrect predicates, context dimensions, or evidence requirements can produce a mechanically correct but scientifically misleading result. Event presence is not observation truth.

Internal validity

The SOVA team authored the mechanism, constructed corpora, most adapters, and the interpretation. Perfect synthetic scores primarily show alignment with the declared rules. Post-result ablations and thresholds are labeled as such.

External validity

The evidence includes deterministic fixtures, one Windows host, four CPython minor versions, official Inspect logs, retrospective WebArena trajectories, one local Collector path, and bounded standard-format conversions. It excludes independently operated production backends, diverse vendor traces, fresh stochastic controlled re-execution, real incidents, and malicious recorders.

Statistical validity

Balanced deterministic corpora do not justify population claims. The retrospective cohort is small, and the scale measurements have no multi-machine variance estimate. Future studies must predeclare denominators, grouping, uncertainty, exclusions, and stopping rules.

Security and privacy validity

The same-team attack matrix is not a cryptographic audit. Signatures and hash chains provide bounded tamper evidence, not truth, freshness, completeness, non-repudiation, or signer honesty. Padding still leaks buckets and structure; omission remains the safest public default for secrets.

9. Reproducibility and confirmatory protocol

The release artifact should contain the safe reference implementation, schemas, fixtures, expected decision vectors, adapters, independent verifiers, experiment scripts, environment locks, result files, and a one-command validation path. Third-party source bytes with unclear redistribution rights must remain excluded and replaced with acquisition instructions and pinned digests.

The confirmatory study must be executed after freezing its protocol and candidate commit. It requires:

- independently authored claim contracts and behavior pairs;
- blinded labels and adjudicator provenance;
- at least two independently operated runtimes;
- controlled real-model re-execution;
- faithful graph, semantic, record/replay, and integrity baselines;
- malicious-recorder and evidence-loss cases;
- independent security, privacy, and artifact review; and
- publication of failures, exclusions, deviations, and negative results.

The current reviewer packet can freeze cases, digests, release order, and scoring rules. It cannot manufacture organizational independence or replace human scientific responsibility.

10. Conclusion

.sova makes an AI-agent security finding a portable, inspectable research object, while .sova-trace makes the evidence boundary explicit. The retained experiments show that the composed decision is executable and expose where byte equality, terminal status, trajectory structure, semantic similarity, integrity validity, and capture-profile names answer narrower questions. The current result is a bounded, falsifiable architecture with adverse evidence retained. Independent cross-runtime validation must still support or falsify its broader usefulness.

Declarations

Ethics and dual-use statement

The reported machine experiments use synthetic or public research fixtures and safe local actions. They do not target a live third party, use client data, store real credentials, or claim access to private model thoughts or hidden chain-of-thought. The work can support security testing and therefore has dual-use potential. Unsafe reproduction remains subject to explicit authorization, containment, and human review; operational exploit details and novelty-sensitive implementations are outside the scope of this public preprint.

Data and artifact availability

The generic SOVA implementation, public specifications, safe examples, and tests are available in the SOVA-OSS repository. The retained result manifests, preregistrations, source digests, build provenance, and reviewer packet used for this preprint are held by TRUSCOR Private Limited and are not part of this paper-only release. Third-party source artifacts whose redistribution rights are unclear are not redistributed. A venue artifact release requires a separate rights, privacy, security, and IP review.

Author contributions and AI-assisted work

Gautam R. Patil conceived the SOVA project, specified the research direction and safety constraints, and directed this work. Software implementation, experiment execution, analysis support, literature discovery, and drafting used OpenAI Codex under his direction. Gautam R. Patil is the sole human author and reviewed and approved the final text, citations, figures, data, declarations, and public release. No AI system is listed as an author or inventor.

Funding and competing interests

This work was conducted for TRUSCOR Private Limited. No external funding was used for the reported machine experiments. The author's affiliation with TRUSCOR Private Limited is a relevant non-financial and potential commercial interest.

References

Arize AI. 2026. *OpenInference Semantic Conventions*. https://github.com/Arize-ai/openinference.

Cer, Daniel, Mona Diab, Eneko Agirre, Inigo Lopez-Gazpio, and Lucia Specia. 2017. "SemEval-2017 Task 1: Semantic Textual Similarity - Multilingual and Cross-Lingual Focused Evaluation." *Proceedings of the 11th International Workshop on Semantic Evaluation*, 1–14. https://doi.org/10.18653/v1/S17-2001.

Duy, Phan The, Khoa Ngo-Khanh, Nguyen Huu Quyen, and Van-Hau Pham. 2026. *PoC-Adapt: Semantic-Aware Automated Vulnerability Reproduction with LLM Multi-Agents and Reinforcement Learning-Driven Adaptive Policy*. https://arxiv.org/abs/2604.06618.

Keller, Drew, Kweku Kwegyir-Aggrey, Ryan Steed, Anita K. Rao, Julia L. Sharp, and A. Stevie Bergman. 2026. *Expanding the AI Evaluation Toolbox with Statistical Models*. https://doi.org/10.6028/NIST.AI.800-3.

Keller, Drew, Ryan Steed, Tony Wang, A. Stevie Bergman, and Peter Cihon. 2026. *Practices for Automated Benchmark Evaluations of Language Models*. https://doi.org/10.6028/NIST.AI.800-2.ipd.

Li, Alex Chengyu. 2026. *AEGIS: A Portable Evidence-Bundle Protocol for Offline Verification of AI-Agent Execution Traces*. https://doi.org/10.2139/ssrn.6392459.

Lim, Soohan, Joonghyuk Hahn, Hyunwoo Park, Sang-Ki Ko, and Yo-Sub Han. 2026. "ContractEval: A Benchmark for Evaluating Contract-Satisfying Assertions in Code Generation." *Findings of the Association for Computational Linguistics: ACL 2026*, 42549–66. https://doi.org/10.18653/v1/2026.findings-acl.2112.

Lu, Xing Han, Amirhossein Kazemnejad, Nicholas Meade, et al. 2025. *AgentRewardBench: Evaluating Automatic Evaluations of Web Agent Trajectories*. https://arxiv.org/abs/2504.08942.

Mudasiru, Rasheed. 2026. *Deterministic Replay for AI Agent Systems*. https://arxiv.org/abs/2607.16200.

OASIS Open. 2021. *STIX Version 2.1*. https://docs.oasis-open.org/cti/stix/v2.1/os/stix-v2.1-os.html.

OpenTelemetry Authors. 2026a. *OpenTelemetry Protocol and Protobuf Definitions*. https://github.com/open-telemetry/opentelemetry-proto.

OpenTelemetry Authors. 2026b. *OpenTelemetry Semantic Conventions 1.43.0*. https://opentelemetry.io/docs/specs/semconv/.

Paduraru, Ciprian, Petru-Liviu Bouruc, and Alin Stefanescu. 2026. *A Trace-Based Assurance Framework for Agentic AI Orchestration: Contracts, Testing, and Governance*. https://arxiv.org/abs/2603.18096.

Pattnayak, Priyaranjan, and Apoorv Bhatia. 2026. "ReproEvalCard: A Reporting Standard for Reproducible Evaluation of LLM Pipelines." *Proceedings of the 64th Annual Meeting of the Association for Computational Linguistics (Volume 2: Short Papers)*, 238–49. https://doi.org/10.18653/v1/2026.acl-short.22.

Qian, Yaoyao, Yuanli Wang, Jinda Zhang, et al. 2025. *WebGraphEval: Multi-Turn Trajectory Evaluation for Web Agents Using Graph Representation*. https://arxiv.org/abs/2510.19205.

Rundgren, Anders, Bret Jordan, and Samuel Erdtman. 2020. *JSON Canonicalization Scheme*. RFC 8785. RFC Editor. https://doi.org/10.17487/RFC8785.

Secure Systems Lab. 2023. *Dead Simple Signing Envelope Protocol 1.0.2*. https://github.com/secure-systems-lab/dsse/blob/master/protocol.md.

Sigstore Authors. 2026. *Sigstore Bundle Format 0.3.2*. https://docs.sigstore.dev/about/bundle/.

Torres-Arias, Santiago, New York University, and Secure Systems Lab. 2019. *In-Toto: A Framework to Secure the Integrity of Software Supply Chains*. https://in-toto.io/.

UK AI Security Institute. 2026. *Inspect AI Evaluation Logs*. https://inspect.aisi.org.uk/eval-logs.html.

Wang, Yiqi, Jiaqi Zhang, Taotao Cai, et al. 2026. *From Agent Traces to Trust: A Survey of Evidence Tracing and Execution Provenance in LLM Agents*. https://arxiv.org/abs/2606.04990.

Wang, Yongchao, and Zhiqiu Huang. 2026. *Security Is Relative: Training-Free Vulnerability Detection via Multi-Agent Behavioral Contract Synthesis*. https://arxiv.org/abs/2604.19012.

World Wide Web Consortium. 2013a. *PROV-AQ: Provenance Access and Query*. https://www.w3.org/TR/prov-aq/.

World Wide Web Consortium. 2013b. *PROV-CONSTRAINTS: Constraints of the PROV Data Model*. https://www.w3.org/TR/prov-constraints/.